

第十一讲 操作系统安全

Part II 基于活动目录的域安全机制

一、Windows 域

1、Workgroup（工作组）管理模型

假设现在工作组内有两台计算机：一台是服务器 Florence（职能：提供资源和分配资源），一台是客户机 Perth。

假设服务器 Florence 提供一个简单的共享文件夹作为服务资源。

任务：要把这个共享文件夹的访问权限授予公司内的员工张建国（注意，这个文件夹只有张建国一个人可以访问！）

一般情况下管理员的思路：

①在服务器上为张建国这个用户创建一个用户账号，如果访问者能回答出张建国账号的用户名和密码，服务器就认可这个访问者就是张建国。

②接下来张建国就在客户机 Perth 上准备访问服务器上的共享文件夹，他准备访问资源\\Florence\\人事档案，服务器对访问者提出了身份验证请求。

③张建国成功地通过了身份验证，访问到了目标资源。

问题：如果这 500 台服务器上都有资源要分配给张建国，那会有什么后果呢？假设公司有 1000 名员工呢？

2、域

解决问题的思路：只要有一台计算机为公司员工创建了用户账号，其他计算机就可以共享账号了。这样就很好地解决了账号重复创建的问题。

域就是共享用户账号、计算机账号和安全策略的计算机集合。

域是一个安全边界。资源在一个域中参与共享。

域中集中存储用户账号的计算机就是域控制器，域控制器存储着目录数据并管理用户域的交互关系，包括用户登录过程、身份验证和目录搜索等。

域模型就是针对大型网络的管理需求而设计的。

一个域中可有一个或多个域控制器，各域控制器间可以相互复制活动目录。（冗余 热备份 双机热备份可靠度 99.95%）

另一个问题：怎么实现用户账号、计算机账号和安全策略等各种资源的共享？

3、活动目录

可能的解决方案：将网络中的各种网络设备、网络服务、网络账号等资源信息集中起来进行管理，为用户提供一个统一的清单。

(1) What is Active Directory?

An Active Directory structure is a hierarchical arrangement of information about objects. The objects fall into two broad categories: resources (e.g., printers) and security principals (user or computer accounts and groups). Security principals are assigned unique security identifiers (SIDs).

Each object represents a single entity - whether a user, a computer, a printer, or a group-and its attributes. Certain objects can contain other objects. An object is uniquely identified by its name and has a set of attributes - the characteristics and information that the object represents - **defined by a schema**, which also determines the kinds of objects that can be stored in Active Directory.

The schema object lets administrators extend or modify the schema when necessary. However, because each schema object is integral to the definition of Active Directory objects, deactivating or changing these objects can fundamentally change or disrupt a deployment. Schema changes automatically propagate throughout the system. Once created, an object can only be deactivated-not deleted. Changing the schema usually requires planning.

(2) 活动目录的数据库

活动目录中存储：对象，属性。

(3) Schema（架构）

活动目录 Schema：■ 随时可用的■ 可动态更新的■ 被
DACLs 保护

架构用来定义 AD 中的对象（classes）和属性（attributes）。活动目录的基础架构（base Schema）包括了比如 user、computer、OU（organizational Unit）等对象以及用户电话号码、objectsid 等属性。

(4) 什么时候适合部署 AD

微软认为，当一个计算机网络中的计算机数量超过 20 台式时，就应该使用 AD 来管理这个网络了。

网络中的计算机数量过于庞大，在针对桌面型维护如软件安装、系统补丁升级、关键应用的实施时，IT 维护人员的工作量剧增，以致影响企业正常运转。这时需要 AD 来做程序的下发工作。

(5) 活动目录 vs. 目录服务

活动目录就其本质来讲，是一种采用 LDAP（轻量级目录访问协议）的目录服务。

活动目录包括两个方面：➤ 目录 ➤ 目录相关的服务

目录是存储各种对象的容器。保存集中管理的共享资源信息，包括服务器信息、文件信息、打印机信息、用户账号等信息。

目录服务的功能：

①**维护目录信息。**

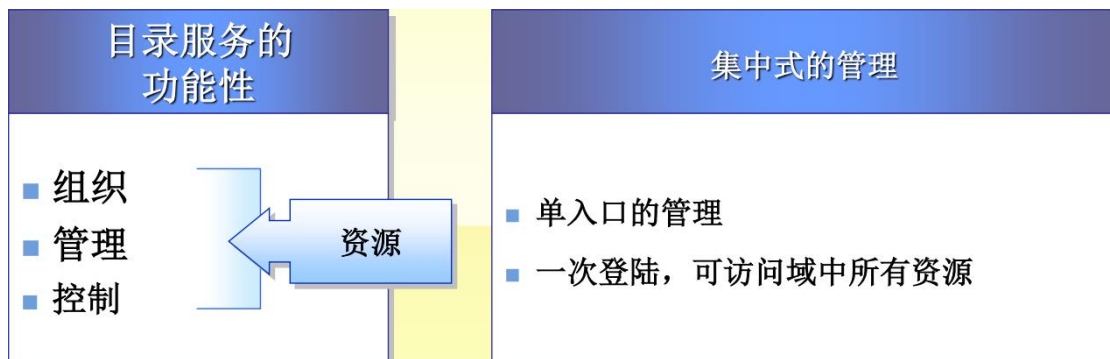
②**数据复制。**如果网络中有多个域控制器，活动目录提供了通过网络分发目录的复制服务。

③**查询机制。**用户或应用程序可以通过活动目录的查询机制找到对象及相关属性。

④**全局编目。**对所管理的资源信息进行全局索引。

⑤**合理组织信息结构。**对管理的资源对象及这些对象的属性、名称的格式等以一种合理的结构进行组织。

为什么需要目录服务？

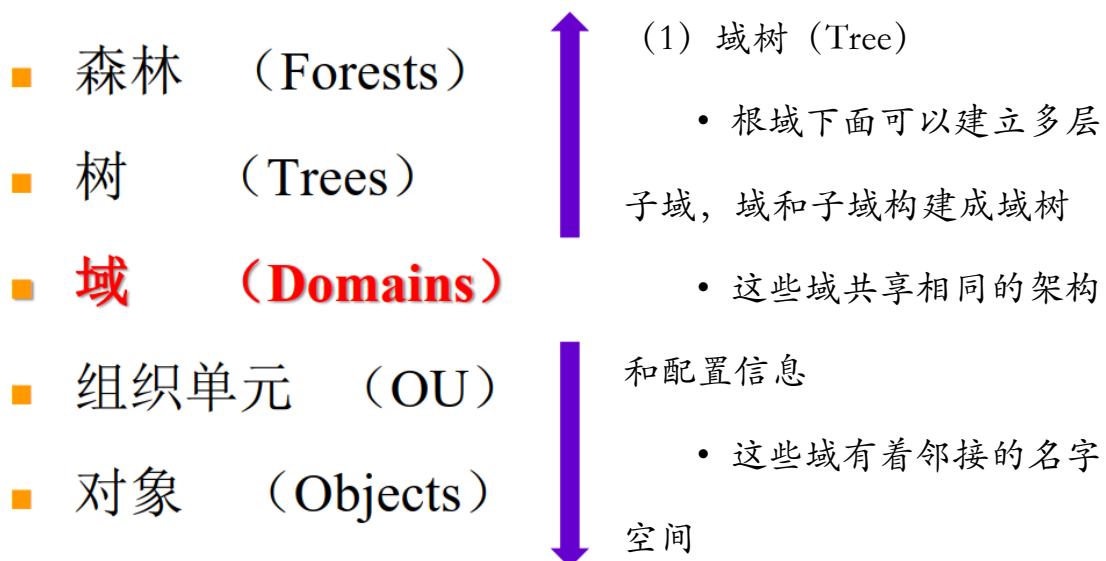


活动目录的地位：是安全体系、管理结构以及资源组织的中心。

二、活动目录的结构

活动目录的结构：逻辑结构、物理结构。

1、活动目录的逻辑结构



(2) 森林 (Forrest)

- 多棵域树构建成森林
- 域之间自动建立双向信任关系

(3) 存放对象及其属性的容器 — 组织单元

OU 是一种类型的目录对象—容器，其作用主要用来委派对用户、组及资源集合的管理权限。

- 控制用户/组对资源的访问
- 建立/应用组策略对象
- 实现管理委派
- 组织具有公共属性的对象，如打印机

2、物理结构

AD 物理结构主要是规划站点拓扑，帮助管理员确定在网络的什么地方放置域控制器，以及管理域控制器之间的复制流量和用户登录流量。

考虑到企业的地理分布情况，应该使用多站点拓扑来规划 AD 物理结构。

每个地理位置中的若干台域控制器可以划分为一个站点。

站点内部优先同步活动目录数据库，同步后再和其他站点中的域控制器同步。

站点反映了活动目录的物理结构。

由于站点内的计算机有着良好的连接，因此用户使用站点来使服务器和网络客户的相关操作都在本地进行，而不需要跨越广域网。

站点目的：

- 优化复制流量
- 使用户登录到 DC,使用一个可靠的、高速的链接

三、AD 的组策略

Group Policy is a hierarchical infrastructure that allows a network administrator in charge of Microsoft's Active Directory to implement specific configurations for users and computers. Group Policy can also be used to define user, security and networking policies at the machine level.

Group Policy allows administrators to define options for what users can do on a network – including what files, folders and applications they can access. The collections of user and computer settings are referred to as Group Policy Objects (GPOs), which are administered from a central interface called the Group Policy Management Console.

(1) 组策略 GPMC — “一对多” 的管理

组策略是 Windows Server 2003 操作系统中提供的一种重要的更新和配置管理技术。

■ 系统管理员使用组策略来为计算机和用户组管理桌面配置指定的选项

■ 组策略很灵活，它包括如下的一些选项：基于注册表的策略设置、安全设置、软件安装、脚本、计算机启动与关闭、用户登录和注销，文件重定向等

■ Windows Server 2003 包括几百种可以配置的组策略设置。组策略设置允许企业管理员通过增强和控制用户桌面来减少总的开销

(2) 组策略的主要优势

- 策略提供大量定制桌面的管理
- 组策略管理控制台 (GPMC) 让管理工作更简单

- RsOP 得到组策略应用的结果
- 降低管理、支持与培训成本
- 提升用户工作效率
- 允许极大量的定制项目 - 其扩展性不会牺牲定制的灵活性

(3) 组策略对象和组策略容器

GPO 设置应用于连接在一个 Site、域、和 OU 中的用户和计算机

- 一个 GPO 可以连接在多个 Site、域、和 OU 上
- 一个 Site、域、和 OU 上可以连接多个 GPO

OU 是挂载组策略的最小单元。

(4) 使用组策略

- 使用组策略管理客户端安全性
- 使用组软件限制策略
- 使用组策略分发软件

(5) 利用组策略部署与管理软件

① 软件生命周期

准备 → 部署 → 维护 → 移除

② 软件部署方法

